Leverancier Onboarding Checklist

ISO 27001:2022 A.5.19, A.5.20, A.5.21, A.5.22

Documentnummer	ISMS-035
Versie	1.0
Classificatie	Intern
Eigenaar	[Naam CISO / Procurement-lead]
Goedgekeurd door	[Naam Directie]
Datum goedkeuring	[DD-MM-JJJJ]
Volgende review	[DD-MM-JJJJ]

1. Doel

Deze checklist operationaliseert het leveranciersbeleid (ISMS-023) tot een concreet stappenplan dat bij **elke nieuwe leverancier of significant uitbreiding van een bestaande leverancier** doorlopen moet worden. Het dicht het grootste auditor-gat bij MKB-organisaties: theoretisch beleid zonder praktische uitvoering.

Na afronding van deze checklist is de leverancier:

- Formeel geregistreerd in het leveranciersregister
- Beoordeeld op security-risico (tier 1/2/3)
- Contractueel gebonden aan passende security-clausules
- Opgenomen in het monitoring-schema (jaarlijks tot per-kwartaal, afhankelijk van tier)
- Klaar voor auditor-review (alle evidence aanwezig)

2. Wanneer toepassen

Deze checklist is verplicht bij:

- Nieuwe leverancier die data of systeemtoegang krijgt
- Bestaande leverancier die een nieuwe dienst gaat leveren met additionele toegang
- Migratie naar nieuwe cloud-provider
- Integratie met een nieuwe SaaS-tool (ook bij "gratis" tools!)
- Wijziging (sub)verwerker bij een bestaande leverancier

Niet vereist bij:

- Eenmalige aankopen zonder dataverwerking (bijv. kantoormeubilair, catering)
- Software zonder netwerk- of datatoegang (bijv. offline grafische tools)

3. Proces-overzicht

Fase	Doel	Verantwoordelijke	Doorlooptijd
1. Behoeftebepaling	Zakelijke rechtvaardiging + data-impact	Proceseigenaar	1-3 dagen
2. Risicotiering	Tier 1 / 2 / 3 classificatie	CISO + Procurement	1-2 dagen
3. Due diligence	Security-assessment proportioneel aan tier	CISO	5-15 dagen
4. Contractualisering	DPA + security-clausules	Legal / Directie	5-10 dagen
5. Technische onboarding	Accounts, toegangen, scheiding	IT-beheer	2-5 dagen
6. Registratie	Opname in leveranciersregister + RoPA	Procurement / DPO	1 dag
7. Monitoring-schema	Inplannen review-ritme	CISO	1 dag

4. Fase 1 — Behoeftebepaling

4.1 Zakelijke rechtvaardiging

- [ ] Welk zakelijk probleem wordt opgelost?
- [ ] Welke alternatieven zijn overwogen (incl. bestaande leveranciers)?
- [ ] Is deze leverancier gevalideerd door een technische POC (proof-of-concept)?
- [ ] Is goedkeuring directie/afdelingshoofd gedocumenteerd?

4.2 Data-impact assessment

- [ ] Worden er persoonsgegevens verwerkt? (indien ja: DPIA-check zie ISMS-029)
- [ ] Welke data-categorieën zien zij (publiek / intern / vertrouwelijk / geheim)?
- [ ] Worden gegevens buiten de EER verwerkt? Zo ja: welke waarborgen (SCC/adequaatheidsbesluit/BCR)?
- [ ] Is er een verbonden AVG-rechtsgrond?

5. Fase 2 — Risicotiering

Classificeer de leverancier in een van drie tiers. Diepte van due diligence schaalt mee.

Tier 1 — Kritiek

Kenmerken (één of meer):

- Verwerkt gevoelige persoonsgegevens (medisch, financieel, strafrechtelijk)
- Heeft admin-toegang tot productie-systemen
- Is single-point-of-failure voor een kernbedrijfsproces
- Hosting van bedrijfskritieke applicaties / data

Voorbeelden: cloudprovider (AWS/Azure/GCP), ERP-SaaS, betalingsverwerker, ziekenhuis-EPD-leverancier

Tier 2 — Belangrijk

Kenmerken:

- Verwerkt persoonsgegevens zonder bijzondere categorieën
- Heeft gestandaardiseerde toegang (rol-gebaseerd, geen admin)
- Vervangbaar binnen 30 dagen zonder grote impact

Voorbeelden: e-mail marketing tool, helpdesk-software, videoconferencing, externe boekhouder

Tier 3 — Laag risico

Kenmerken:

- Geen persoonsgegevens of alleen basis contactgegevens
- Geen systeemtoegang
- Gemakkelijk vervangbaar

Voorbeelden: CDN, DNS-provider, domain-registrar (zonder e-mail), marketing-analytics-tool (zonder PII)

6. Fase 3 — Due diligence per tier

6.1 Tier 1 — Uitgebreide assessment

- [ ] **Certificering**: ISO 27001-certificaat aangevraagd + geverifieerd bij CI
- [ ] **SOC 2 Type II rapport** opgevraagd (niet alleen Type I)
- [ ] **Penetration test-rapport** (minimaal 12 maanden oud, door externe partij)
- [ ] **BCP/DRP documentatie** met RTO/RPO
- [ ] **Laatste incident-overzicht** (2 jaar terug) met remediation
- [ ] **Data-locatie + sub-verwerkers**-lijst
- [ ] **Technische beveiligingsmaatregelen** formulier ingevuld (versleuteling, MFA, access-reviews, logging)
- [ ] **Site-visit of video-audit** (optioneel, voor grote contracten)
- [ ] **Financial health check** (bij grote contracten: risico dat ze failliet gaan met uw data)
- [ ] **Exit-strategie** voorbereid: hoe krijgen we data terug bij opzegging?

6.2 Tier 2 — Standaard assessment

- [ ] Security-vragenlijst (standaardformulier, 30-50 vragen) ingevuld
- [ ] **Certificering of gelijkwaardig attest** (ISO 27001 / SOC 2 / Cyber Essentials)

- [ ] **Data-locatie** (EER-garantie of adequate waarborgen)
- [ ] **Incident-notificatie** commitment binnen 24-72 uur
- [ ] **Sub-verwerkers**-lijst (indien van toepassing)

6.3 Tier 3 — Minimale verificatie

- [ ] Publieke privacy/security-statement gecheckt
- [ ] Privacy-beleid voldoet aan AVG
- [ ] Geen bekende reputatieschade (Google + NCSC-waarschuwingen)

6.4 Red flags — afwijzen of escaleren

Bij één of meer van onderstaande: minimaal escaleren naar CISO + directie.

- Weigert basis-vragenlijst in te vullen
- Geen formele security-contactpersoon
- Geen incident-notificatie proces
- Geen onafhankelijke audit / certificering bij Tier 1/2
- Datalek-historie < 12 maanden zonder aantoonbare remediation
- Sub-verwerkers in sanctie-landen of zonder waarborgen
- Prijsmodel onverklaarbaar laag (suggestie van zwak security-investering)

7. Fase 4 — Contractualisering

7.1 Standaard clausules die altijd in contract moeten

- [ ] **Vertrouwelijkheid**: NDA / geheimhouding (liefst wederkerig)
- [ ] **Aansprakelijkheid**: min. jaarcontractwaarde aan direct schade
- [ ] **Incident-notificatie**: binnen [24-72] uur na detectie
- [ ] **Audit-recht**: u mag hun security (of via onafhankelijke partij) auditen
- [ ] **Sub-verwerkers**: alleen met uw goedkeuring, en doorwerking clausules
- [ ] **Data-teruggave/vernietiging** bij einde contract (termijnen, formaat, certificaat van vernietiging)
- [ ] **Back-up en beschikbaarheid**: SLA met meetbare KPI's
- [ ] **Rechtsgebied**: NL/BE-rechter, EER-recht

7.2 Persoonsgegevens: Verwerkersovereenkomst (VWO/DPA)

Bij verwerking van persoonsgegevens **verplicht** onder AVG Art. 28:

- [ ] Onderwerp + duur van verwerking
- [ ] Aard + doel van verwerking
- [ ] Type persoonsgegevens + categorieën betrokkenen
- [ ] Verplichtingen + rechten verwerkingsverantwoordelijke
- [ ] Vertrouwelijkheid personeel verwerker
- [ ] Technische & organisatorische maatregelen

- [ ] (Sub)verwerker-clausules (goedkeuring, doorwerking)
- [ ] Assistentie bij AVG-verzoeken van betrokkenen
- [ ] Assistentie bij datalekken (Art. 33-34)
- [ ] Auditrechten voor de verwerkingsverantwoordelijke
- [ ] Data-teruggave/vernietiging na einde

7.3 Sector-specifieke clausules

- **NIS2** (essentiële/belangrijke entiteiten): meldingsplicht doorwerking, compliance-statement
- **NEN 7510** (zorg): patient-data-bescherming-clausule
- **BIO** (overheid): BIV-classificatie, ENSIA-compatibiliteit

8. Fase 5 — Technische onboarding

8.1 Accounts + toegangen

- [ ] Apart account per leverancier (geen gedeelde accounts)
- [ ] Principe **least privilege**: alleen rechten die strikt nodig zijn voor de dienst
- [ ] **MFA** verplicht op leverancier-accounts
- [ ] **Just-in-time access** waar mogelijk (toegang alleen tijdens afgesproken window)
- [ ] Session-logging + review (voor Tier 1)

8.2 Netwerk-scheiding

- [ ] Toegang via **jump-host** / **bastion** (niet direct op productie)
- [ ] **Dedicated VPN** of **Zero Trust** (geen platte VPN-toegang)
- [ ] Firewall-rules specifiek voor de leverancier, documenteerbaar
- [ ] Segmentatie per klant/project (vooral bij MSP-relaties)

8.3 Data-integratie

- [ ] **API-keys** uniek per leverancier, rotatie-schema afgesproken
- [ ] **Webhook-endpoints** met IP-whitelist (indien mogelijk)
- [ ] Inkomende data-flow gevalideerd + gemonitord
- [ ] Uitgaande data-flow beperkt tot noodzakelijke velden

9. Fase 6 — Registratie

- [ ] Opname in **Leveranciersregister** (ISMS-leveranciers.xlsx)
- [ ] Koppeling in **RoPA** (ISMS-030) als er persoonsgegevens bij betrokken zijn
- [ ] Opname in **Asset-register** (ISMS-008) als het systeem/dienst een asset wordt
- [ ] Documentatie-links naar: VWO/DPA, security-vragenlijst, certificaten, pentests

10. Fase 7 — Monitoring-schema

Tier	Hercheck frequentie	Activiteiten
Tier 1	Elk kwartaal	SLA-review · incident-overzicht · nieuwe CVE-alerts · certificaat nog geldig?
Tier 2	Jaarlijks	Security-vragenlijst herzien · certificaat verlengd? · incidenten afgelopen jaar
Tier 3	Bij contractverlenging	Basic check: privacy-statement nog actueel, geen reputatieschade

Resultaten van monitoring worden vastgelegd en zijn onderdeel van de management review (ISMS-022).

11. Exit-procedure

Bij beëindiging van de relatie:

- [ ] Contractuele opzegtermijn gerespecteerd
- [ ] Data-exporteren + ontvangst-bevestigen
- [ ] **Bewijs van data-vernietiging** (certificaat met methode + datum)
- [ ] Accounts gedeactiveerd (verwijderd of disabled + gearchiveerd)
- [ ] API-keys + credentials geroteerd
- [ ] Firewall-rules & VPN-toegangen verwijderd
- [ ] Documenten in register gemarkeerd "beëindigd" (niet verwijderd — audit-trail)
- [ ] **Post-exit beoordeling**: wat ging goed/slecht, lessons learned voor volgende leverancier

12. Templates & tools

Deze documenten ondersteunen de procedure:

- `leveranciers-register.xlsx` — centraal register
- `security-vragenlijst-tier2.docx` — standaard due diligence
- `dpa-template.docx` — VWO/DPA-template AVG
- `contract-security-clausules.docx` — bouwstenen contract
- `exit-checklist.docx` — uittredeprocedure

13. Audit-trail

Elke voltooide onboarding levert:

- Ingevulde checklist (deze) met datum + handtekening CISO
- Alle aangevraagde documenten in het leveranciersregister
- Getekende contracten + VWO/DPA
- Eerste monitoring-kalender-entry

Auditor kan per leverancier dit complete pakket opvragen.

14. KPI's

KPI	Doel
% nieuwe leveranciers met volledige checklist afgerond	100%
Gemiddelde doorlooptijd onboarding Tier 1	≤ 30 dagen
Gemiddelde doorlooptijd onboarding Tier 2	≤ 14 dagen
Tier 1-leveranciers met certificaat op orde	100%
Aantal leveranciers dat de jaarlijkse monitoring-check op tijd passeerde	≥ 95%

15. Ondertekening

Naam CISO	[Naam]
Handtekening	_____
Datum	[DD-MM-JJJJ]